



Activités d'audit

Présenté par : Nozha KABSI



1) Déclenchement de l'audit

Nomination du responsable de l'audit

- Pour chaque audit, il ne doit y avoir qu'un seul responsable d'audit nommé par l'organisme d'audit.
- Principales responsabilités:
 - Planifier l'audit et identifier & traiter les risques de l'audit;
 - Gérer les communications avec le client et l'audit;
 - Gérer l'équipe d'audit;
 - Assigner les responsabilités pour chaque auditeur;
 - Résoudre les conflits;
 - Etablir les conclusions d'audit;
 - Rédiger le rapport d'audit.

Etablissement du contact initial avec l'audité

- Réalisé par le responsable de l'équipe d'audit, les objectifs sont:
 - Mieux comprendre l'organisme;
 - Etablir les circuits de communication;
 - Rappeler les objectifs de l'audit;
 - Informer sur le calendrier et la composition de l'équipe de l'audit;
 - Demander l'accès aux documents pertinents;
 - Déterminer les règles de sécurité applicables concernant le traitement des informations confidentielles;
 - Prendre les dispositions logistiques;
 - Se mettre d'accord sur la présence d'observateurs et de guides pour accompagner l'équipe d'audit.

Etablissement du contact initial avec l'audité

– Validation des objectifs d'audit lors du premier contact:

Dans un audit de certification ISO 27001, les principaux objectifs d'audit sont de confirmer que:

- Le SMSI est conforme aux exigences de la norme;
- L'organisme a mis en œuvre le SMSI déclaré, qu'il est maintenu et qu'il s'améliore:
- L'organisme est en mesure d'atteindre les objectifs de sécurité qu'il s'est fixés.

Etablissement du contact initial avec l'audité

- **Validation du périmètre de l'audit** lors du premier contact:
 - Le périmètre de l'audit décrit l'étendue et les limites de l'audit: généralement les lieux, les unités organisationnelles, les activités, les processus ainsi que la période de temps couverte par l'audit.
 - Le périmètre de l'audit n'inclut pas nécessairement tout le périmètre du SMSI: possibilité de recours à l'échantillonnage qui doit être bien justifié.
 - Le périmètre de l'audit choisi par l'auditeur doit être représentatif du périmètre du SMSI.



Etablissement du contact initial avec l'audité

– Cas de changement du périmètre du SMSI ou de l'audit

- Tout changement du périmètre du SMSI ou de l'audit doit faire l'objet d'un accord signé entre l'auditeur, le client de l'audit et l'audité.
- Les changements doivent être documentés.
- S'il n'y a pas d'accord sur un changement du périmètre, l'auditeur choisit entre:
 - Continuer l'audit avec le périmètre initial;
 - Se retirer et informer les différentes parties prenantes de l'impossibilité de remplir la mission d'audit.

L'auditeur doit toujours évaluer l'impact des changements du périmètre avant de fournir son opinion et doit consulter l'organisme de certification avant qu'une décision ne soit prise.

Etablissement du contact initial avec l'audité

- **Validation des critères d'audit** lors du premier contact:
 - Dans un audit de certification, le critère d'audit est la norme ISO 27001 avec l'ensemble des mesures déterminées suite au processus de traitement des risques.
 - L'audit peut inclure des critères supplémentaires issus de:
 - Autres normes/standards;
 - Politiques internes;
 - Lois et règlements;
 - Contrats;
 - Codes de déontologie sectoriels.

Détermination de la faisabilité de l'audit

La faisabilité de l'audit doit être déterminée en prenant en considération des facteurs tels que:

- L'existence d'informations suffisantes et appropriées pour planifier et réaliser l'audit;
- Coopération adéquate de la part de l'audité;
- Ressources (exemple les compétences de l'équipe d'audit) et temps nécessaires pour réaliser l'audit;
- Les aspects culturels (exemple langue à utiliser lors de l'audit).

Lorsque l'audit n'est pas faisable, il convient qu'une contre proposition soit faite au client de l'audit en concertation avec l'audité.

Quelle est la durée d'un audit?

Annexe C, ISO 27006

Nombre d'employés	Temps d'audit (jours/homme) ISO 9001	Temps d'audit (jours/homme) ISO 27001
1 à 10	2	5
26 à 45	4	8,5
66 à 85	6	11
176 à 275	9	14
876 à 1175	13	18,5
2026 à 2675	16	22
4351 à 5450	19	25
8501 à 10700	22	28

Signature d'un contrat

Dans un audit de certification ISO 27001, il s'agit de la signature d'un contrat de certification dont les termes d'engagement incluent:

- Les objectifs de l'audit;
- Les critères de l'audit;
- Le périmètre de l'audit;
- la période de temps couverte par l'audit;
- Les responsabilités en matière de gestion;
- risque de détection : le fait que, compte tenu de la nature du test, il existe un risque inévitable que certaines erreurs demeurent non détectées;
- L'accès sans restriction à toute information en rapport avec les objectifs de l'audit;
- Un accord concernant la planification et l'exécution de l'audit.

Sélection de l'équipe d'audit

Exemple de critères de sélection

Compétences	
Chaque auditeur	Au moins un membre de l'équipe
Capacité à travailler en équipe	Connaissance du secteur d'activité de l'organisme
Connaissance adéquate en sécurité de l'information et en gestion des risques	Expertise sur chaque domaine à auditer
Connaissance des normes, des procédures et des techniques d'audit	Connaissance des exigences légales et réglementaires liées à l'audité
Compréhension des principaux processus de gestion d'entreprise	
Habileté de communication orale et écrite	

Refus d'un auditeur par l'audité ou le client d'audit

- Le client d'audit ou l'audité peut demander le remplacement d'un membre de l'équipe de l'audit pour des motifs valables.
- Exemples de motifs valables:
 - Auditeur en situation de conflit d'intérêt ;
 - Auditeur qui a précédemment fait preuve de comportement contraire à la déontologie;
 - Auditeur qui n'a pas l'habilitation de sécurité requise par l'audité.
- l'équipe d'audit pourrait se désister si elle juge que les motifs invoqués sont non valables.



2) Audit d'étape 1

Objectifs de l'audit d'étape 1

- Auditer la documentation du SMSI mis en place par l'audité;
- Evaluer le lieu et les conditions spécifiques au site de l'audité;
- Déterminer le niveau de préparation pour l'audit d'étape 2 de l'audité;
- Procéder à une revue de la compréhension des exigences de la norme par l'audité;
- Réunir les informations nécessaires à l'audit d'étape 2;
- Convenir avec l'audité des détails de l'audit d'étape 2;
- Déterminer si les audits internes et la revue de direction ont été planifiés et réalisés.

Activités à effectuer

- Evaluation des lieux et des conditions spécifiques des sites à auditer;
- Prise de contact avec le personnel de l'audité;
- Observation des technologies utilisées;
- Observation générale des opérations du SMSI.

Entretiens avec les principaux intervenants

- L'objectif à cette étape n'est pas de récolter des preuves d'audit pour valider la conformité du SMSI.
- L'objectif est de s'assurer une compréhension adéquate des enjeux auxquels l'organisme fait face (contraintes légales, réglementaires et contractuelles, besoins des clients, politiques internes, etc.) et de la façon dont le SMSI y répond.

intervenant	Objectif de l'entretien
Responsable SMSI	Mieux comprendre le SMSI et valider que ses composantes principales sont conformes aux exigences de la norme
Un représentant de la direction	Valider l'engagement de la direction et sa compréhension des exigences de la norme en termes de responsabilités de la direction
Auditeur interne	valider que l'activité d'audit interne est effectuée de manière adéquate et régulière

Principaux objectifs

- Compréhension globale du fonctionnement du SMSI;
- Evaluation de la conception du SMSI ainsi que des processus et mesures liées;
- Vérification que les audits internes et la revue de la direction ont été réalisés.

Revue des documents – critères d'évaluation

Contenu

Format

**Procédure de
gestion des
documents et des
enregistrements**

S'assurer que:

- chaque document contient les informations exigées par la clause associée;
- chaque document est conforme en termes de format : identification de l'auteur, date de production, numéro de version, approbation, date de la dernière révision, etc.
- Il existe une procédure pour gérer le cycle de vie des documents et des enregistrements en conformité avec les exigences de la norme.

Revue des documents – Types de documents à auditer

Examen des documents dans l'ordre suivant:

- Documentation stratégique: déclaration du périmètre, objectifs de sécurité, politiques, etc.
- Documentation liée à la gestion du risque;
- Documentation des processus et mesures de sécurité;
- Documentation des procédures;
- Documentation d'appui aux procédures : fiches de travail, formulaires, listes de contrôle, etc.
- Vérification des enregistrements.

Revue des documents

- L'auditeur doit s'assurer que l'ensemble des documents indiqués dans les clauses 4 à 10 de l'ISO 27001 sont présents et conformes. L'absence de l'un de ces points sera documentée comme étant une non-conformité majeure.
- si une mesure qui n'est pas une exigence de la norme est documentée avec le verbe « doit », l'auditeur doit la valider comme une exigence du système de management.

Exemple

- Si une procédure indique que les sauvegardes **doivent** être vérifiées chaque matin à 10:00 et que l'auditeur constate lors de l'audit sur site que ce n'est pas le cas, il y aura une non-conformité.
- Par contre, si la même procédure était écrite avec le verbe « **devraient** », il n'y aurait pas de non-conformité à constater car il ne s'agirait que d'une ligne directrice que l'organisme s'est donnée.

Rapport d'audit d'étape 1

- Les résultats d'audit d'étape 1 doivent être documentés et communiqués au client de l'audit et à l'audité, y compris l'identification de tout problème susceptible d'être classé comme une NC au cours de l'audit d'étape 2.
- En cas de détection de NCs lors de l'audit documentaire, c'est plus avantageux pour l'audité de prendre le temps d'apporter les corrections nécessaires à la documentation de son SMSI et de soumettre la documentation corrigée à l'équipe d'audit avant de procéder à l'audit d'étape 2.



3) Préparation de l'audit d'étape 2

Objectif de l'audit d'étape 2

- Evaluer la mise en œuvre et l'efficacité du SMSI, en particulier si le SMSI:
 - Est conforme à toutes les exigences de la norme ISO 27001;
 - Est effectivement mise en œuvre dans l'organisme;
 - Permet à l'organisme d'atteindre ses objectifs de sécurité.

Préparation du plan d'audit

Plan d'audit (ISO 19011):

description des activités et des dispositions nécessaires pour réaliser un audit.

- Il sert comme un accord entre l'organisme de certification, l'équipe d'audit et l'audité en ce qui concerne la réalisation de l'audit.
- Préparé par le responsable de l'équipe d'audit.
- Revu et confirmé par le client de l'audit et l'audité avant de débiter les activités de l'audit d'étape 2.

Préparation du plan d'audit

Contenu du plan d'audit (ISO 19011 6.3.2.2)

- Les objectifs d'audit;
- Le champ/périmètre de l'audit;
- Les critères d'audit;
- Les lieux & les dates & l'horaire et la durée prévus des activités d'audit;
- Les rôles et responsabilités des membres de l'équipe d'audit, des guides et des observateurs;
- L'affectation des ressources appropriées;
- Les méthodes d'audit à utiliser (y compris l'échantillonnage, le cas échéant);
- Autres: exemple: la logistique et les moyens de communication.

Répartition des tâches au sein de l'équipe d'audit

L'attribution des responsabilités d'audit devrait tenir compte de:

- **Les conditions particulières de la mission d'audit:** objectifs, périmètre et critères d'audit, la durée, les lieux, etc.
- **La compétence globale de l'équipe d'audit:** expertise nécessaire, capacités de communication des membres de l'équipe avec l'audit: compréhension de la langue et des caractéristiques sociales et culturelles particulières, etc.
- **Des considérations propres à chaque auditeur :** Absence de conflits d'intérêt, disponibilité, niveau d'expérience, expertises particulières, langues parlées, etc.

Répartition des tâches au sein de l'équipe d'audit

- Si les auditeurs ne couvrent pas entièrement les compétences nécessaires, celles-ci peuvent être satisfaites par le recours à des experts techniques ayant des compétences complémentaires pour soutenir l'équipe.
- Les experts techniques doivent opérer sous la direction d'un auditeur .

Préparation des documents de travail

- Préparés par les membres de l'équipe d'audit;
- Servent de références et d'enregistrements de l'audit;
- Peuvent comprendre:
 - Des guides d'entretien;
 - Un compte-rendu de réunions;
 - Des listes de contrôles (check-lists);
 - Des plans d'échantillonnage; etc.
- Conserver les documents de travail , y compris les enregistrements résultants de leurs utilisation jusqu'à la fin de la mission.

Préparation des documents de travail

- Assurer la protection des documents de travail car ils contiennent des informations confidentielles.
- Le responsable de l'équipe d'audit a la responsabilité d'établir une procédure normalisée de documentation qui contiennent des lignes directrices en matière de documentation d'audit:
 - Langue à utiliser;
 - Supports à utiliser: logiciel d'audit, templates d'audit, etc.
 - Utilisation d'abréviations;
 - Documentation des preuves d'audit.

Préparation des documents de travail

Utilisation des listes de contrôles (check-lists)

- ✓ Guider l'auditeur;
- ✓ Structurer et standardiser l'approche d'audit;
- ✓ Garder à l'esprit les objectifs;
- ✓ garantir un minimum de couverture lors de l'audit.
- ✓ Economiser le temps d'audit;
- ✓ Conserver des enregistrements d'audit.





4) Audit d'étape 2

Conduite de la réunion d'ouverture

ISO 19011, 6.4.3

- C'est une réunion entre l'équipe d'audit et les principaux acteurs impliqués dans la gestion du SMSI de l'audité.
- Elle se déroule pendant le premier jour sur le site de l'audité avant le début de la collecte d'informations.
- Le responsable de l'équipe d'audit préside généralement la réunion.



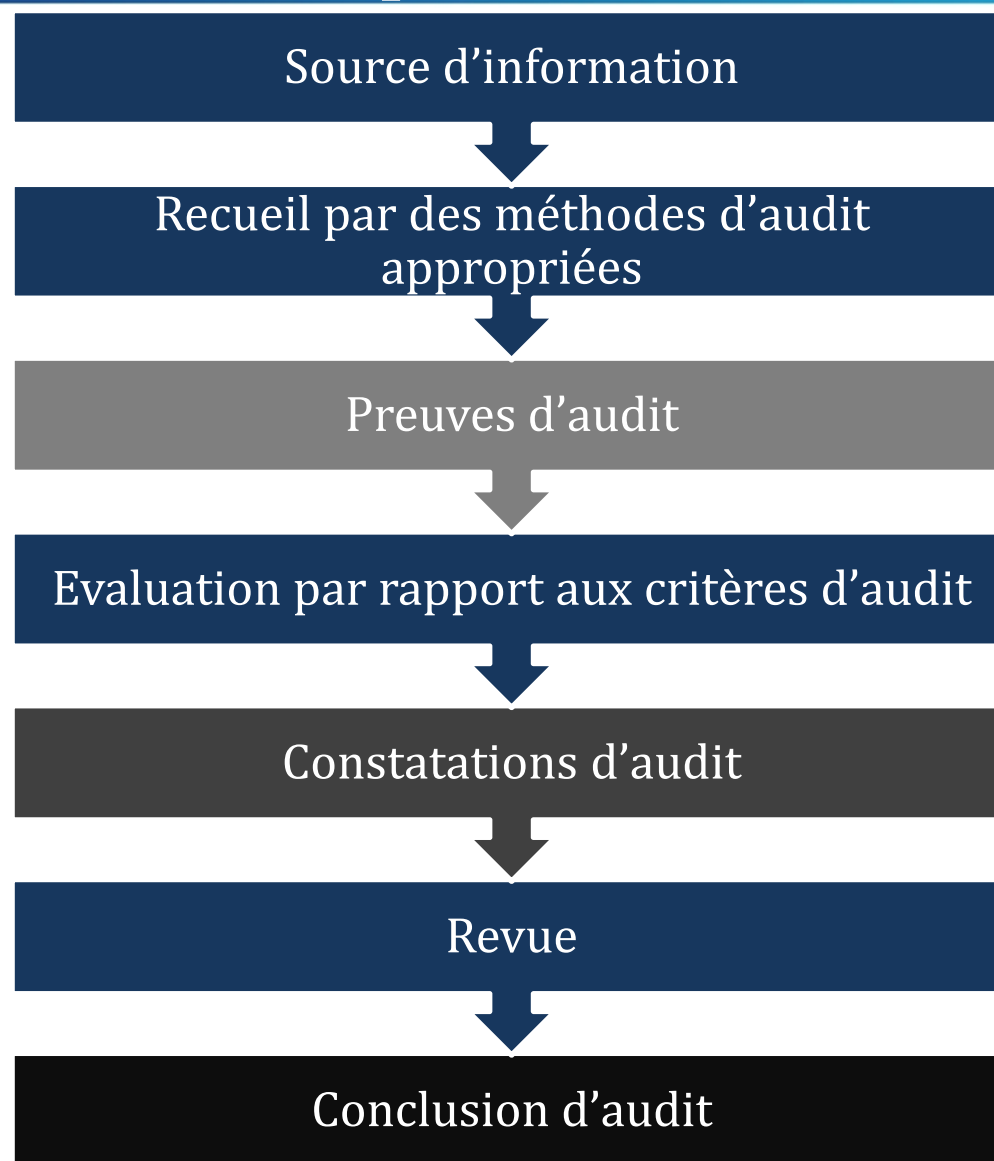
Ordre de jour de la réunion d'ouverture

- Il convient que les sujets suivants soient évoqués:
 - ✓ Présentation des participants;
 - ✓ La confirmation des objectifs, du champ et des critères de l'audit;
 - ✓ La confirmation du plan d'audit;
 - ✓ Présentation des méthodes et procédures d'audit utilisées;
 - ✓ La confirmation des circuits de communication formels;
 - ✓ La confirmation de la disponibilité des ressources et de la logistique nécessaires à l'équipe d'audit;
 - ✓ La confirmation des dispositions de confidentialité ainsi de santé/sécurité sur les lieux de travail;
 - ✓ Informations sur la manière de traiter les constats éventuels au cours de l'audit;
 - ✓ Informations sur tout système de retour d'information de l'audité sur les constats ou les conclusions d'audit;
 - ✓ Informations sur la réunion de clôture.

Présentation générale du processus d'audit

ISO 19011, 6.4.7

Processus type d'audit depuis le
recueil d'informations
jusqu'aux conclusions d'audit



- **Mesure de sécurité:** l'attribution des droits d'accès à l'application financière de l'organisme doit être approuvée préalablement par le propriétaire de l'application: **critère interne formulé par l'audité.**
- **Source d'information:** Les formulaires d'autorisation signés.
- **Preuves d'audit:** l'échantillon de formulaires d'autorisation signés.
 - ➔ Lorsque l'auditeur sélectionne et obtient des informations, elles deviennent des preuves d'audit. Ces preuves d'audit n'ont pas encore été analysées par l'auditeur.
- **Constats d'audit:** Suite à une analyse des preuves d'audit % critères d'audit, l'auditeur doit faire un constat sur le respect de ces critères:
 - 3 formulaires d'accès sur un échantillon de 25 n'ont pas été signés par le propriétaire de l'application ➔ Respect partiel des critères ➔ NC mineure
- **Conclusion d'audit:** un autre auditeur effectue une revue de qualité.
 - Suite aux commentaires du réviseur, l'auditeur modifie son constat à une non-conformité majeure car les formulaires non conformes sont liés à des demandes de droits d'accès à des systèmes critiques. Par la suite, l'auditeur formule sa conclusion d'audit: recommandation défavorable à la certification.

méthodes d'audit

- Utilisés de manière unique ou en combinaison afin de récolter des preuves pour évaluer la conformité d'un SMSI.
- Un audit peut être réalisé en utilisant une gamme de méthodes d'audit.
- L'application de différentes méthodes d'audit combinées permet d'optimiser l'efficacité et l'efficience du processus d'audit et de ses résultats.

méthodes d'audit

Catégories des méthodes les plus fréquemment utilisées lors des audits

Méthode	Exemple
L'observation	Observation de la présence d'un dispositif de protection d'incendie ou le déroulement du processus de sauvegarde
La revue documentaire	examen d'une politique de sécurité ou d'une procédure
L'entretien	Interview d'un responsable en ressources humaines pour comprendre et valider comment sont conservés les dossiers des employés
L'analyse/ étude par échantillonnage	Analyse d'un échantillon de 30 PCs d'un parc info contenant 500 PCs afin de vérifier qu'ils possèdent un antivirus à jour
La vérification technique	vérifier la configuration système avec l'admin afin de valider les paramètres de sécurité de Windows (politique du mot de passe, politique du compte verrouillé, etc.),
La corroboration	Comparer les réponses d'entretiens avec la documentation
L'évaluation	A-t-on assez de preuves suffisantes, appropriées et fiables pour avoir une assurance raisonnable et générer un constat?

Documentation des observations

- 1) **Prise de notes:** exemples: les personnes observées, caractéristiques du matériel observé (marque, numéro de série, ...).
- 2) **Photocopies de documents** (objet d'un accord avec l'audité): exemple: photocopie d'une partie ou du sommaire du document vérifié.
- 3) **Prise de photos ou enregistrements audio/vidéo** (objet d'un accord avec l'audité): exemple: pour les mesures de sécurité physique.

Préparer un entretien

- 1) Définir les objectifs à atteindre lors de l'entretien;
- 2) Etablir la liste précise des thèmes à couvrir;
- 3) Ecrire un plan d'entretien avec une liste de contrôles ou questionnaire;
- 4) Déterminer les personnes interviewées en relation avec les activités du SMSI;
- 5) Prendre rendez-vous;
- 6) Préparer les documents de travail.

Démarrer un entretien

- 1) Expliquer les objectifs de l'entretien et les sujets à couvrir;
- 2) Informer sur le respect de la confidentialité (si l'interviewé désire conserver l'anonymat);
- 3) Expliquer le but des prises de notes;
- 4) Initier l'entretien en demandant de décrire son implication dans le SMSI ainsi que ses rôles et responsabilités.



Conduire un entretien

- ✓ Utiliser des questions ouvertes telles que:
 - Qui, quoi, où, pourquoi, quand, comment;
 - Montrez-moi, dites-moi, expliquez-moi;
- ✓ Éviter les questions fermées (réponses par oui/non);
- ✓ Éviter les questions guidées: exemple: vos employés sont tous sensibilisés à la sécurité de l'information, n'est-ce-pas?
- ✓ On peut commencer par une question fermée pour débiter un point puis aller avec des questions ouvertes:
 - Avez-vous une Politique ****? Expliquez-moi *****
- ✓ S'assurer de couvrir l'ensemble des sujets en maîtrisant le temps;
- ✓ Prendre des notes durant l'entretien;
- ✓ Poser des questions pour clarifier une réponse ou une situation.

Conclure un entretien

- ✓ Les résultats de l'entretien doivent être résumés et revus avec la personne interviewée;
- ✓ La personne interviewée doit être remerciée pour sa participation et sa collaboration;
- ✓ Les documents/actions que l'interviewé a promis de fournir doivent être notés au cours de l'entretien et récapitulés à la fin de l'entretien.

Suite à l'entretien

- ✓ Compléter les documents de travail avant de passer à une autre occupation;
- ✓ Envoyer un email de remerciement avec un compte rendu d'entretien tout en rappelant de la liste des documents/actions promis avec une deadline;
- ✓ Suivre les éléments convenus lors de l'entretien.

- ✓ Elle permet aux auditeurs de tirer des conclusions au sujet d'un tout en y examinant une partie.
- ✓ Elle permet d'estimer des caractéristiques d'une population en observant directement une partie de l'ensemble de la population.
- ✓ La confiance qui peut être accordée aux conclusions d'audit est étroitement liée à l'utilisation appropriée de l'échantillonnage lors de la mission d'audit.

Principales définitions

- ❑ **Population:** Ensemble des personnes, des objets ou des éléments sur lesquels on veut effectuer l'étude.
- ❑ **Individu:** Chacun des éléments de la population.
- ❑ **Caractère:** Caractéristique relative à chacun des individus de la population et sur laquelle on veut faire porter l'étude.
- ❑ **Echantillon:** sous-ensemble des individus de la population étudiée.

Exemples d'éléments souvent validés à l'aide d'échantillonnage lors d'un audit ISO 27001:

- formation et sensibilisation (7.2 & 7.3)
- Diffusion et compréhension de la PSI (A.5.1.1)
- Attribution des responsabilités (A.6.1.1)
- Propriété des actifs (A.8.1.2)

Utilisation d'une table d'échantillonnage:

- fréquemment utilisée,
- Table proposée par le IT Governance Institute:

Nature de la mesure de sécurité à auditer	Fréquence d'opération	Nombre minimum de sélections
Manuelle	Plusieurs fois par jour (ou pop : +366)	25
Manuelle	Quotidien (ou pop : 53-365)	15
Manuelle	Hebdomadaire (ou pop : 13-52)	5
Manuelle	Mensuel (ou pop : 5-12)	2
Manuelle	Annuel / Trimestriel (ou pop : 1-4)	1
Automatisée	Examiner l'application de chaque mesure de sécurité automatisée	

Exemples d'utilisation de la table d'échantillonnage:

- ❑ Une procédure de mise à jour système effectuée 2 fois/semaine
→ Échantillon de 15
- ❑ Une copie de sauvegarde effectuée matin et soir
→ Échantillon de 25
- ❑ Un département de 70 employés
→ Échantillon de 15
- ❑ Un parc informatique de 8 ordinateurs
→ Échantillon de 2

La vérification technique

Afin de valider l'efficacité technique d'un processus ou d'une mesure de sécurité, l'auditeur peut demander d'assister à:

- Analyse des configurations;
- Production réelle ou simulation: exemple: assister à la restauration d'une copie de sauvegarde;
- Balayage « scanning ».

La corroboration

- C'est le fait de vérifier les informations pour s'assurer d'une certaine qualité des preuves.
- Exemples:
 - Poser les mêmes questions à différentes personnes et comparer les réponses;
 - Comparer les réponses d'entretiens avec la documentation;
 - Comparer les documents ou notes d'entretiens avec des observations directes.

L'évaluation

- C'est l'acte par lequel l'auditeur juge les résultats des procédures précédentes afin de s'assurer que les preuves sont suffisantes, appropriées et fiables.
- l'auditeur doit évaluer la qualité et la quantité d'information: « A-t-on assez de preuves fiables pour avoir une assurance raisonnable? »
- Les preuves d'audit doivent être évaluées par rapport aux critères de l'audit afin de générer les constats d'audit.
- Méthode plus subjective qui repose sur l'expérience de l'auditeur.

méthodes d'audit

Sélectionner une combinaison de méthodes d'audit applicables pour valider une mesure de sécurité

Exemple: Enregistrement et désinscription des utilisateurs, clause A.9.2.1

Un processus formel d'enregistrement et de désinscription des utilisateurs doit être mis en œuvre pour permettre l'attribution des droits d'accès.

Observation	Observer l'inscription et/ou la désinscription des accès d'un utilisateur
Document	Politique sur la gestion des accès, formulaires d'approbation, résultats de la révision des accès effectuée par les propriétaires, déclaration des utilisateurs attestant leur compréhension de leurs responsabilités, matrice des droits d'accès
Entretien	Le directeur du centre de service (pour confirmer les aspects couverts par la politique sur la gestion des accès) et un analyste du centre de service (pour valider la compréhension et le respect de la politique)
Vérification technique	Vérifier les configurations et le fonctionnement des systèmes d'enregistrement des utilisateurs
Analyse	Sélectionner un échantillon de demandes d'accès et valider si la politique/procédure de gestion des accès a été suivie

Constats d'audit

Types de constats possibles

Conformité

Situation dans laquelle toutes les exigences ont été satisfaites

Observation

Situation pouvant être l'objet d'une amélioration continue sans constituer pour autant une non-conformité

Aucune obligation de mettre en œuvre des actions correctives suite à une observation

Exemple: un auditeur peut indiquer que l'organisme audité pourrait mettre en œuvre un système de gestion documentaire qui gère automatiquement les documents

Non-Conformité mineure

Situation dans laquelle un aspect de la mise en œuvre ou de l'application d'une mesure n'a pas été rempli

Devrait être corrigée lors du prochain audit, pourrait compromettre la certification à l'avenir

Exemples: Qques contradictions observées dans le rapport d'appréciation des risques
Qques procédures n'ont pas été revues et māj dans le délai prévu par l'organisme

Non-Conformité majeure

Absence de conformité à une exigence requise ou échec total de son efficacité

Présence d'une NC majeure entraîne une recommandation négative quant à la certification.

Exemple: Personnel en charge de gérer des mesures de séc critiques du SMSI qui n'a pas les qualifications nécessaires

Documentation d'une non-conformité

- Si un constat d'audit est une non-conformité, l'auditeur doit le documenter
- 3 éléments pour documenter une non-conformité:
 - ✓ Description de la non-conformité constaté avec les preuves
 - ✓ Description des exigences pour lesquelles la non-conformité a été détectée
 - ✓ Rapport de non-conformité (mineure ou majeure)

Documentation d'une non-conformité

Exemple:

Rapport de Non-Conformité		
Audit: GHOURABI Technologies	Site: Siège	N° de la non-conformité: 2 Date: 16/09/2020 Catégorie: Majeure
Processus: Gestion des actifs	Clause: A.8.1.1	
Critère d'audit: L'information et autres actifs associés à l'information et aux moyens de traitement de l'information doivent être identifiés et un inventaire de ces actifs doit être dressé et tenu à jour.		
Description de la non-conformité observé: sur un échantillon de 25 actifs analysés de la liste des actifs, uniquement 5 actifs sont correctement identifiés.		
Reconnaissance du représentant audité: Non-conformité présentée à Monsieur Elyes GHOURABI et confirmée le 15/09/2020.		Auditeur: Anis GHANMI

Echanges entre Auditeur & audité

Auditeur	Audité	
1) Constats d'audit	2) Confirmation ou fourniture des informations supplémentaires	Audit sur site
3) Conclusions d'audit	4) Commentaires	
5) Réunion de clôture et rapport d'audit Etape 2	6) Acceptation ou Contestation	
8) Evaluation des plans d'action	7) Plans d'action en cas de Non-Conformités	Audit de suivi le cas échéant
10) Audits de surveillance	9) Mise en place des plans d'action	Audits de surveillance

Recommandation de certification

- Suite aux conclusions d'audit, l'auditeur doit formuler l'une des quatre recommandations suivantes quant à la certification:
 - 1) Recommandation pour la certification;
 - 2) Recommandation pour la certification sous condition de dépôt d'un plan d'action de mesures correctives sans visite préalable;
 - 3) Recommandation pour la certification sous condition de dépôt d'un plan d'action de mesures correctives avec visite préalable;
 - 4) Recommandation défavorable.

Discussion des conclusions de l'audit avec l'audité

- Il est important de discuter les constats et les conclusions de l'audit avec l'audité avant la réunion de clôture et le dépôt du rapport final afin de:
 - ✓ Éviter toute méprise et tout malentendu
 - ✓ Corroborer les conclusions avec la direction
 - ✓ Donner à l'audité la possibilité de répondre à certaines questions et de fournir de nouvelles preuves
 - ✓ S'assurer que les faits présentés dans le rapport sont exacts et que les conclusions de l'audit sont comprises par la direction

Conduite de la réunion de clôture

ISO 19011, 6.4.10

- C'est une réunion entre l'équipe d'audit et des représentants de la direction de l'audité;
- Possibilité de participation des personnes responsables des fonctions ou processus audités;
- Elle se déroule pendant le dernier jour sur le site de l'audité;
- Le responsable de l'équipe d'audit préside la réunion.



Ordre de jour de la réunion de clôture

- ✓ Remerciements;
- ✓ Rappel des objectifs, du champ et des critères de l'audit;
- ✓ Présentation des conclusions de l'audit et de la recommandation quant à la certification;
- ✓ Présentation des non-conformités;
- ✓ Limitations;
- ✓ Questions/réponses;
- ✓ Suites de l'audit.

Préparation du rapport d'audit

ISO 19011, 6.5.1

- Préparé par le responsable de l'équipe de l'audit;
- Le rapport d'audit doit être complet, précis, concis et clair.
- Contenu:
 - ✓ Les objectifs d'audit;
 - ✓ Le champ de l'audit;
 - ✓ L'identification du client de l'audit;
 - ✓ L'identification de l'équipe de l'audit et des participants de l'audité ;
 - ✓ Les dates et les lieux où les activités d'audit ont été réalisées;
 - ✓ Les critères d'audit;
 - ✓ Les constatations d'audit et les preuves associées;
 - ✓ Les conclusions d'audit;
 - ✓ Une déclaration sur le degré de conformité aux critères d'audit.

Diffusion du rapport d'audit

ISO 19011, 6.5.2

- Le rapport d'audit doit être:
 - ✓ Émis dans les délais convenus;
 - ✓ Daté, revu et approuvé;
 - ✓ Diffusé aux destinataires préalablement désignés par le client de l'audit.

ISO 19011, 6.6

- L'audit est fini lorsque toutes les activités décrites dans le plan d'audit ont été réalisées;
- Il convient de conserver ou de détruire les documents relatifs à l'audit comme convenu entre les parties participantes et conformément aux procédures du programme d'audit et aux exigences applicables.